



Powered by **Arizona State University®**

Alumno: Luis Alberto Vargas González.

Fecha: 27/05/2026.

**Tarea : U3 A1: Reporte del desarrollo de un plan integral de
continuidad de operaciones.**

Maestría en Ciberseguridad.

INDICE.

1. Portada.
2. Introducción.
3. Investigación y selección del programa de rco.
4. Análisis de impacto en la continuidad de operaciones.
5. Planteamiento del sistema para la continuidad de operaciones.
6. Estrategias para la recuperación de operaciones.
7. Respuesta a incidentes de seguridad.
8. Implementación y pruebas del plan.
9. Conclusió.
10. Referencias.

INTRODUCCIÓN.

En el ecosistema contemporáneo de la tecnología educativa (*EdTech*), la disponibilidad ininterrumpida de los servicios digitales constituye el núcleo de la viabilidad institucional y reputacional. Para la Universidad Digital de las Américas (UDA), una organización nativa digital que brinda servicios de educación superior a una matrícula activa de más de 5,000 estudiantes distribuidos geográficamente, la infraestructura tecnológica *no es un soporte*; es el negocio mismo. Al operar bajo un modelo 100% virtual y con un entorno totalmente desplegado en la nube de Amazon Web Services (AWS), la superficie de ataque y los vectores de falla lógica se magnifican.

Frente a un panorama de amenazas caracterizado por el auge de ataques de *Ransomware* altamente dirigidos a sectores académicos y denegaciones de servicio (DDoS) automatizadas, las estrategias reactivas de TI resultan obsoletas. Este informe técnico documenta el diseño integral del Plan de Continuidad de Operaciones (BCP) y el Plan de Recuperación ante Desastres (DRP) para la UDA. A través de un análisis metódico, se evalúan las herramientas de replicación del mercado, se formaliza el Análisis de Impacto al Negocio (BIA), se estructuran los comités de crisis bajo el principio de segregación de funciones y se detalla un Plan de Respuesta a Incidentes basado en las mejores prácticas internacionales (NIST SP 800-61 r2). El objetivo final es dotar a la UDA de una postura de resiliencia proactiva, minimizando la pérdida de datos y garantizando la continuidad del ciclo académico ante cualquier evento disruptivo.

INVESTIGACIÓN Y SELECCIÓN DEL PROGRAMA DE RCO.

Programa / Herramienta	Características y Funcionalidades Clave	Requisitos e Impacto en Infraestructura	Costo, Escalabilidad y Viabilidad
Veeam Availability Suite	• Excelente granularidad para la recuperación de objetos de bases de datos. • Orquestación avanzada de <i>fail-over</i> y copias de seguridad de alta velocidad. • Soporte multi-plataforma.	• Requiere el despliegue de agentes en las instancias de cómputo. • Complejidad alta para la sincronización continua directa en arquitecturas puramente <i>cloud-native</i>.	• Esquema de licenciamiento por capacidad o instancia activa. • Costo operativo elevado debido a la duplicidad de cómputo en la nube.
Azure Site Recovery (ASR)	• Sincronización casi en tiempo real. • Orquestación nativa para entornos virtuales. • Excelente para esquemas de recuperación en nubes híbridas.	• Exige una arquitectura de destino basada estrictamente en Microsoft Azure. • Requiere la configuración de túneles VPN dedicados o ExpressRoute entre nubes.	• Modelo de pago por uso según el número de instancias protegidas. • Viabilidad técnica baja debido a la latencia que introduce la comunicación <i>inter-cloud</i>.
AWS Elastic Disaster Recovery (AWS DRS)	• Replicación continua a nivel de bloque (CDR) de forma asíncrona.	• Integración nativa mediante agentes ligeros de replicación a nivel de sistema	• Seleccionado. Altamente rentable (pago por uso: solo se cobra por el alma-

Programa / Herramienta	Características y Funcionalidades Clave	Requisitos e Impacto en Infraestructura	Costo, Escalabilidad y Viabilidad
	• Lanzamiento automatizado de instancias en minutos. • Pruebas de recuperación no disruptivas en entornos aislados.	operativo. • Requiere la configuración de un área de preparación (<i>Staging Area</i>) en una región secundaria de AWS.	cenamiento de replicación básica). • Escalabilidad ilimitada dentro de la infraestructura global de AWS.

Justificación Técnica de la Selección de AWS DRS

Se determina que **AWS Elastic Disaster Recovery (AWS DRS)** es la solución óptima para la UDA. Al ser la infraestructura core de la universidad (SSO y LMS Canvas) un entorno nativo de AWS, AWS DRS permite mitigar los riesgos de compatibilidad a nivel de hipervisor. La herramienta destaca por su tecnología de replicación continua a nivel de bloque, lo que significa que cualquier cambio en la base de datos de calificaciones o en las entregas de los alumnos se copia de forma asíncrona en milisegundos hacia una región geográfica secundaria (ej. de AWS Virginia a AWS Oregón).

Esto minimiza drásticamente el uso de ancho de banda y evita la degradación del rendimiento del LMS en producción. Además, económicamente introduce el concepto de *Staging Area* de bajo costo (utilizando instancias de cómputo mínimas tipo t3.micro y discos duros económicos de tipo elásticos para la réplica), activando las instancias de producción de alto rendimiento (tipo m5) únicamente cuando se ejecuta un simulacro o se declara un desastre real.

ANÁLISIS DE IMPACTO EN LA CONTINUIDAD DE OPERACIONES.

Para dimensionar los requerimientos de resiliencia, se realizó un Análisis de Impacto al Negocio enfocado en las tres operaciones más críticas para la supervivencia operativa y financiera de la UDA. Para cada una se definen: el Periodo Máximo Tolerable de Disrupción (**MTPD**), el Objetivo de Tiempo de Recuperación (**RTO**) y el Objetivo de Punto de Recuperación (**RPO**).

A. Operación Crítica: Autenticación Unificada y Control de Acceso (Portal SSO)

- **Activo de Información Asociado:** Servidor de identidades (Directorio Activo / OAuth 2.0), bases de datos de tokens de sesión activos y llaves criptográficas de validación.
- **Amenazas de Alto Impacto:** Ataques de Denegación de Servicio Distribuido (DDoS) volumétricos dirigidos a saturar los endpoints de la API de autenticación; ataques de ingeniería social dirigidos (*Spear Phishing*) para comprometer credenciales con privilegios de administrador global.
- **Métricas Críticas:**
 - **MTPD:** 2 horas. Pasado este tiempo, la imposibilidad de acceso genera un colapso en cascada de todas las plataformas, provocando la pérdida de sesiones de exámenes y saturando los canales de soporte técnico.
 - **RTO:** 45 minutos. Tiempo límite para realizar la conmutación por error (*failover*) del portal de acceso hacia la infraestructura de contingencia.
 - **RPO:** 15 minutos. Máxima pérdida aceptable de registros de inicio de sesión; este margen evita que los usuarios activos experimenten desconexiones masivas y requieran reautenticarse.

B. Operación Crítica: Impartición de Cátedras y Evaluaciones en Línea (LMS Canvas)

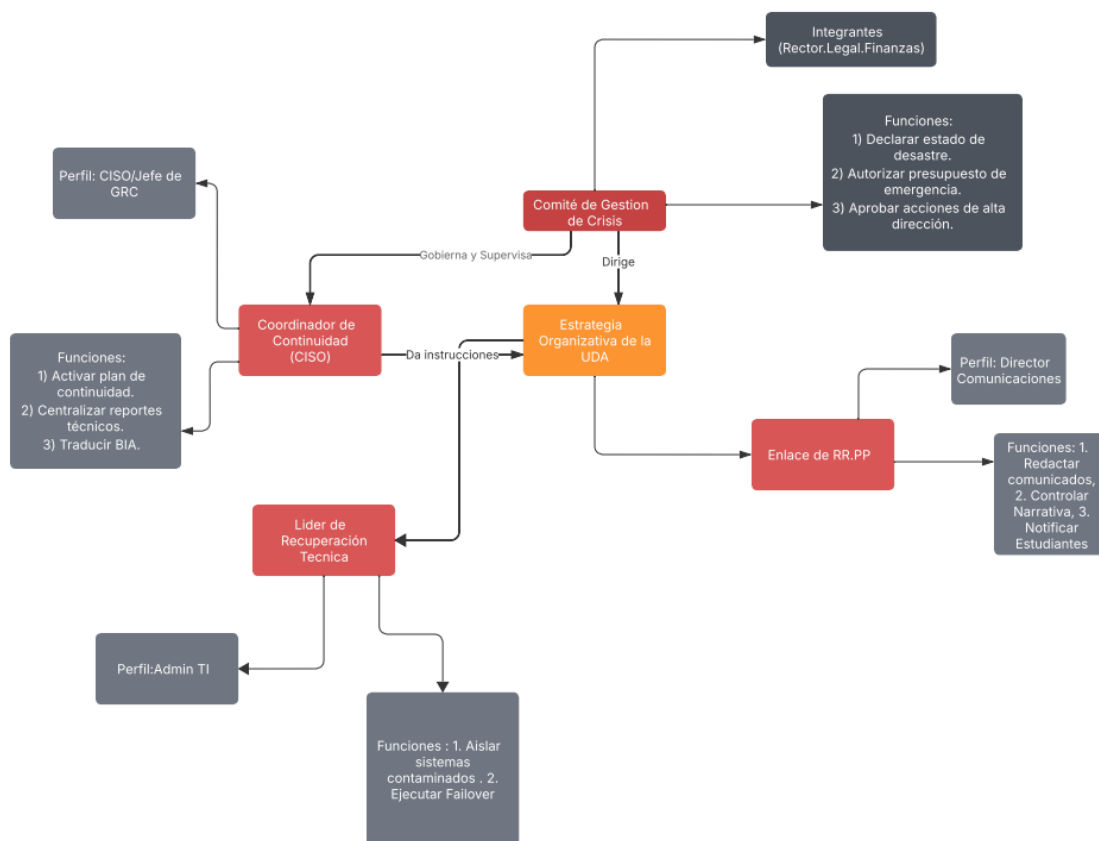
- **Activo de Información Asociado:** Repositorios de contenido multimedia, bases de datos relacionales de tareas, exámenes activos, foros de discusión e historial de navegación estudiantil.
- **Amenazas de Alto Impacto:** Infección por *Ransomware* con cifrado de los volúmenes de almacenamiento en la nube; errores de configuración lógicos en la base de datos durante actualizaciones críticas del núcleo del LMS.
- **Métricas Críticas:**
 - **MTPD:** 8 hours. Ventana máxima tolerada antes de incurrir en un incumplimiento grave de los calendarios escolares oficiales y violaciones normativas ante las autoridades educativas.
 - **RTO:** 3 horas. Tiempo asignado para levantar y verificar la disponibilidad de toda la pila de la aplicación web y la consistencia de las bases de datos en la región secundaria.
 - **RPO:** 1 hora. Margen de pérdida de datos tolerable; ante un desastre, un alumno perdería como máximo el progreso de las entregas realizadas en la última hora.

C. Operación Crítica: Procesamiento de Matrículas, Pagos y Facturación

- **Activo de Información Asociado:** Base de datos del ERP financiero, logs de la pasarela de pagos integrada y registros de transacciones bancarias web.
- **Amenazas de Alto Impacto:** Ataques de inyección de código SQL (SQLi) destinados a la alteración de balances financieros o robo de datos de tarjetas; caídas lógicas de las APIs de comunicación con los bancos adquirentes.
- **Métricas Críticas:**
 - **MTPD:** 24 horas. La institución puede subsistir un día sin procesar nuevas transacciones financieras antes de que se vea afectado el flujo de caja operativo.
 - **RTO:** 6 horas.
 - **RPO:** 0 minutos (Consistencia Estricta). Tolerancia cero a la pérdida de datos financieros. Todas las transacciones deben contar con mecanismos de replicación síncrona o duplicidad en logs de transacciones distribuidos para evitar discrepancias contables.

PLANTEAMIENTO DEL SISTEMA PARA LA CONTINUIDAD DE OPERACIONES.

El Sistema de Gestión de Continuidad de Negocio (SGCN) de la UDA se estructura bajo un enfoque de gobernanza formal que mitiga la improvisación mediante directrices claras y una matriz de responsabilidades bien definida.



Directriz de la Política General de Continuidad (SGCN-POL-01)

"Toda plataforma, microservicio o repositorio de información clasificado con un RTO menor o igual a 4 horas en el BIA institucional tiene la obligación técnica de permanecer enrolado de forma activa en el esquema de replicación asíncrona de AWS DRS. Queda estrictamente prohibido realizar cambios estructurales en los entornos de producción sin verificar previamente la compatibilidad de los agentes de réplica en la región de contingencia."

Estructura Organizativa y Matriz de Roles (RACI)

Para coordinar los esfuerzos durante la activación del plan de continuidad, se establece un Equipo de Respuesta a Incidentes Tecnológicos (IRTI) con los siguientes perfiles:

- **Comité de Gestión de Crisis (CGC):** Integrado por el Rector, el Director de Finanzas y el Asesor Legal. Posee la autoridad exclusiva para declarar formalmente el "Estado de Desastre", autorizar presupuestos de emergencia y tomar decisiones estratégicas de alta dirección.
- **Coordinador de Continuidad (CISO):** Actúa como el enlace táctico-estratégico. Dirige la activación del plan, centraliza los reportes técnicos del equipo defensivo (Blue Team) y traduce el estado de la situación tecnológica en impactos de negocio para el Comité de Crisis.
- **Líder de Recuperación Técnica (LRT):** Comandado por el Administrador de Infraestructura de TI y los ingenieros de ciberseguridad. Su responsabilidad es operativa: aislar los entornos comprometidos, verificar la integridad de las réplicas y ejecutar las tareas de *failover* técnico en la consola de AWS.
- **Enlace de Comunicación y Relaciones Públicas:** Responsable exclusivo de redactar y difundir los comunicados oficiales dirigidos a docentes, alumnos y medios externos, controlando la narrativa para mitigar el impacto reputacional.

ESTRATEGIAS PARA LA RECUPERACIÓN DE OPERACIONES.

Aprovechando la flexibilidad y escalabilidad de la nube, la UDA implementa una estrategia de **Recuperación en la Nube Inter-Región (Cross-Region Disaster Recovery)** utilizando un modelo de arquitectura *Pilot Light* optimizado a través de las siguientes fases procedurales:

Fase 1: Arquitectura de Replicación y Aislamiento (Mitigación de Riesgos)

- Se despliega el agente ligero de **AWS DRS** a nivel de volumen de bloque lógico (EBS) en todos los servidores virtuales de producción ubicados en la región principal de **AWS Virginia (us-east-1)**.
-
- Los datos se transmiten comprimidos y cifrados bajo el estándar **AES-256** hacia un área de preparación (*Staging Area*) dedicada en la región secundaria de **AWS Oregón (us-west-2)**.
- Para mitigar el riesgo de que un *Ransomware* contamine los respaldos, la cuenta de AWS de la zona de contingencia está separada lógicamente mediante *AWS Organizations*, utilizando políticas de control de servicios (SCP) que impiden la modificación o eliminación de puntos de recuperación históricos sin una autenticación multifactor basada en hardware (MFA Key) custodiada por el CISO.

Fase 2: Ejecución del Failover (Restauración de Sistemas)

Ante una interrupción catastrófica, el proceso de restauración técnica sigue este flujo automatizado:

- 1º El CISO instruye al LRT iniciar el proceso de *Failover* desde la consola de AWS DRS en la región de Oregón.
- 2º AWS DRS cesa la replicación asíncrona y lee el último punto de consistencia seguro en el tiempo.
- 3º A través de scripts de orquestación preconfigurados (*CloudFormation*), el sistema convierte de forma automática los discos del *Staging Area* en volúmenes de producción de alto rendimiento y lanza instancias EC2 escaladas (pasando de instancias ligeras t3 de bajo costo a instancias m5.large operativas).

Se ejecutan los *scripts* internos de verificación de salud (*Health Checks*) de las aplicaciones para validar la consistencia de las bases de datos de Canvas y el SSO.

Fase 3: Redirección del Tráfico Global

Una vez que las plataformas se encuentran operativas en Oregón, se modifica la capa de red global:

- Se invoca la API de **AWS Route 53** para aplicar las políticas de enrutamiento por falla (*Failover Routing Policy*).
-
- El registro DNS primario lms.uda.edu.mx se desactiva de la región de Virginia y se apunta con un tiempo de vida (TTL) de 60 segundos hacia el balanceador de carga (ALB) de la región de Oregón, restableciendo el servicio global.

RESPUESTA A INCIDENTES DE SEGURIDAD.

Frente a un ataque deliberado de *Ransomware* enfocado en destruir la disponibilidad del LMS, el equipo de ciberseguridad opera bajo el ciclo de vida de manejo de incidentes del estándar **NIST SP 800-61 r2**:

Fase 1: Detección y Análisis

- **Mecanismo de Detección:** El sistema de detección de anomalías de **AWS GuardDuty** levanta una alerta crítica al identificar llamadas a la API inusuales y un cifrado masivo de bloques de datos en los volúmenes EBS de la base de datos de producción.
- **Notificación:** El sistema dispara una alerta automatizada mediante Amazon SNS (Simple Notification Service) hacia el dispositivo del CISO y el canal de emergencias del equipo técnico en un tiempo menor a 5 minutos.
- **Análisis:** Los ingenieros de seguridad analizan los logs del SIEM para confirmar la naturaleza del incidente, clasificándolo como "Incidente Crítico de Pérdida de Integridad y Disponibilidad por Malware".

Fase 2: Contención Táctica

- **Aislamiento de Red:** Se modifica de forma automatizada el *Security Group* (firewall virtual) de las instancias EC2 infectadas en la región de Virginia. Se bloquea todo el tráfico de entrada y salida de Internet, permitiendo únicamente el acceso a una VPN de administración forense aislada. **No se apagan los servidores**, preservando la memoria RAM para el posterior análisis de artefactos forenses volátiles.
- **Contención de Identidades:** Se revocan de inmediato los tokens de sesión de las cuentas de administrador comprometidas y se deshabilitan temporalmente las llaves de acceso de AWS IAM asociadas al vector de ataque detectado.

Fase 3: Erradicación y Transición a la Continuidad

- **Declaración de Desastre:** Al validar que el Ransomware ha comprometido la base de datos operativa y que el tiempo de limpieza manual superará las 2 horas, el CISO notifica al Comité de Crisis, el cual autoriza formalmente activar el DRP.
- **Activación del Failover:** El LRT ejecuta la restauración en la región de Oregón a través de **AWS DRS**. El sistema levanta las instancias limpias utilizando el último punto de replicación de bloque seguro (RPO de 1 hora atrás), antes de que el Ransomware iniciara el cifrado.
- **Erradicación en Producción:** Mientras la universidad opera desde Oregón, el equipo técnico aplica el parche de ciberseguridad correspondiente en el código de la API en Virginia y elimina las persistencias del malware en las imágenes base (AMIs).

Fase 4: Actividad Post-Incidente (Lecciones Aprendidas)

- Dentro de las 72 horas posteriores al cierre del incidente, el CISO convocará a una reunión obligatoria con todo el equipo de TI y los líderes institucionales.
- Se documentará la línea de tiempo exacta del ataque, se evaluará la efectividad de las herramientas de monitoreo y se actualizarán las firmas del WAF. El informe final (*Lessons Learned Report*) se archivará como parte del proceso de mejora continua del SGCN para robustecer las defensas de la UDA ante futuros vectores de ataque.

IMPLEMENTACIÓN Y PRUEBAS DEL PLAN.

La mera documentación del plan no garantiza su efectividad; por ello, la UDA establece una estrategia de despliegue y validación continua apoyada en la solución DRaaS seleccionada.

Despliegue Operativo del Plan

- **Enrolamiento:** Se realiza la instalación del agente de replicación de AWS DRS en el 100% de los servidores lógicos del alcance. El tráfico inicial de sincronización se programa durante la ventana de menor actividad estudiantil (domingos de 02:00 a 05:00 horas) para evitar la saturación del ancho de banda.
- **Manuales de Operación:** Se redactan Guías de Operación Estandarizadas (SOP) que detallan los comandos específicos y accesos requeridos para interactuar con la consola de AWS en caso de contingencia.

Estrategia de Simulacros y Validación (Sin Disrupción)

Para evaluar la efectividad del plan sin afectar la experiencia de los estudiantes, se pautan dos tipos de pruebas periódicas:

1º **Simulacros de Escritorio (Tabletop) - Trimestrales:** Sesiones de trabajo dirigidas por el CISO donde el Comité de Crisis y los líderes de TI repasan verbalmente los flujos de comunicación y toma de decisiones ante un escenario hipotético de crisis (ej. caída masiva de AWS o ataque de secuestro de datos).

2º **Pruebas Técnicas de Inyección de Fallas (Drills) - Semestrales:** Aprovechando que **AWS DRS** permite lanzar instancias de prueba en una red virtual (VPC) completamente aislada en Oregon sin interrumpir los servidores de producción de Virginia, se ejecutarán simulacros técnicos reales. Estas pruebas medirán si el sistema clonado es consistente y si los ingenieros logran completar el levantamiento de las plataformas dentro de las metas fijas del RTO.

DOCUMENTACIÓN, REVISIÓN CONTINUA E INFORME FINAL.

La resiliencia operativa es un proceso dinámico que debe quedar respaldado por evidencias sólidas y un compromiso de actualización constante por parte de la organización.

Mantenimiento y Revisión del SGCN

Toda la documentación que compone el BCP/DRP de la UDA se someterá a una revisión obligatoria de forma anual o inmediatamente después de que ocurra un cambio significativo en la arquitectura tecnológica de la universidad (como la migración de un microservicio o el cambio de la pasarela de pagos). Los resultados de las pruebas técnicas y las bitácoras de los simulacros se consolidarán en un Reporte Anual de Madurez de Continuidad, el cual será auditado por el área de GRC bajo las directrices de la norma **ISO 19011 para garantizar la mejora continua del sistema.**

CONCLUSIÓN.

El codiseño e implementación del Plan de Continuidad de Operaciones y Recuperación Tecnológica para la Universidad Digital de las Américas (UDA) demuestra que la supervivencia de una organización nativa digital depende de la automatización, la claridad en la gobernanza y el análisis metódico de sus dependencias. Limitar la seguridad a la prevención es una estrategia incompleta; la institución debe estar preparada para asumir que los sistemas eventualmente fallarán o serán comprometidos.

La selección estratégica de **AWS Elastic Disaster Recovery (AWS DRS)** provee a la UDA de una ventaja competitiva fundamental: la capacidad de responder a fallas catastróficas del centro de datos o ataques críticos de *Ransomware* mediante una restauración automatizada inter-región en cuestión de minutos. Al definir con precisión las métricas de RTO y RPO a través del BIA, formalizar la separación de funciones entre los equipos operativos y de gobernanza, y adoptar un marco de respuesta estructurado bajo estándares internacionales como NIST, la UDA transforma la ciberseguridad de un centro de costos técnico a un habilitador estratégico del negocio. Este enfoque integral garantiza la continuidad de su misión educativa, protege la integridad de la información de sus estudiantes y salvaguarda la reputación institucional ante el dinámico y hostil panorama de riesgos del entorno digital actual.

REFERENCIAS.

- Organización Internacional de Normalización (ISO). (2019). *ISO 22301:2019 Seguridad y resiliencia — Sistemas de gestión de la continuidad del negocio — Requisitos*. Ginebra, Suiza.
- Instituto Nacional de Estándares y Tecnología (NIST). (2012). *Computer Security Incident Handling Guide* (NIST Special Publication 800-61, Revision 2). Departamento de Comercio de los Estados Unidos.
- Amazon Web Services. (2024). *AWS Elastic Disaster Recovery User Guide: Technical Architecture and Continuous Replication*. AWS Documentation.